МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ
РОССИЙСКОЙ ФЕДЕРАЦИИ
Федеральное государственное автономное образовательное учреждение
высшего образования
«ТЮМЕНСКИЙ ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ»
ШКОЛА КОМПЬЮТЕРНЫХ НАУК

ОТЧЕТ
О РЕЗУЛЬТАТАХ УЧЕБНО-ЛАБОРАТОРНОГО ПРАКТИКУМА

ТЮМЕНСКИЙ ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ
(наименование организации)

Специализированная лаборатория сетей и систем передачи данных (317 / УЛК №5)

(наименование структурного подразделения)

Выполнил
обучающийся ___2__ курса,
_____КБ-24.01___ группы _____ (подпись) Мирочков В.Д. (ФИО)

Выполнил
обучающийся __2__ курса,
_____КБ-24.01___ группы _____ (подпись) Лодыгонов В.С. (ФИО)

Руководитель практики
от школы _____ (подпись) Хохлов Ю.Ю. (ФИО)

Тюмень, 2026

Продолжение отчета

Защищен 25.06 2026

Результаты экзамена / зачета отл.

Хапаев Ш.Н.

(подпись руководителя практики от школы)

МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ
РОССИЙСКОЙ ФЕДЕРАЦИИ
Федеральное государственное автономное образовательное учреждение
высшего образования
«ТЮМЕНСКИЙ ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ»
ШКОЛА КОМПЬЮТЕРНЫХ НАУК

ИНДИВИДУАЛЬНОЕ ЗАДАНИЕ
ДЛЯ ПРОХОЖДЕНИЯ УЧЕБНО-ЛАБОРАТОРНОГО ПРАКТИКУМА

_____Ларионов_Владимир_Сергеевич_____
(ФИО обучающегося)

Обучающийся ___2___ курса
Форма обучения _____очная_____
(очная, заочная, очно-заочная)

Направление подготовки/специальность 10.05.01 Компьютерная безопасность «Безопасность компьютерных систем и сетей (связь, информационные и коммуникационные технологии)»
Наименование организации Специализированная лаборатория сетей и систем передачи данных (317 / УЛК №5)
(место прохождения практической подготовки)

Сроки прохождения практики _____с 09.06.2026 по 24.06.2026_____

Индивидуальное задание (план работы):

1. Сбор и анализ информации по главам: 3 Актуальные задачи специалистов по информационной безопасности и 4 Перспективы развития информационной безопасности.
2. Сравнение информации на основании анализа, результаты анализа и сравнение.
3. Подготовка 3 и 4 главы отчета о прохождении практики, выводы по проделанной работе.

Обучающийся _____ Ларионов В.С.
(подпись) (ФИО)

Руководитель практики _____ Колбеков М.И.
(подпись) (ФИО)

МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ
РОССИЙСКОЙ ФЕДЕРАЦИИ
Федеральное государственное автономное образовательное учреждение
высшего образования
«ТЮМЕНСКИЙ ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ»
ШКОЛА КОМПЬЮТЕРНЫХ НАУК

ДНЕВНИК ПРОХОЖДЕНИЯ
УЧЕБНО-ЛАБОРАТОРНОГО ПРАКТИКУМА

Ларионов Владимир Сергеевич
(ФИО обучающегося)

Форма обучения очная
(очная, заочная, очно-заочная)

Обучающийся 2 курса
Направление подготовки/специальность 10.05.01 Компьютерная безопасность «Безопасность компьютерных систем и сетей (связь, информационные и коммуникационные технологии)»
Место прохождения практики Специализированная лаборатория сетей и систем передачи данных (317 / УЛК №5)
Сроки прохождения практики с 09.06.2026 по 24.06.2026

Инструктаж по охране труда и правилам техники безопасности проведен ответственным за проведение инструктажей обучающимся от института

09.06.2026	Хохлов М.И.	
(дата)	(ФИО инструктирующего)	(подпись инструктирующего)

С инструкцией по охране труда и правилам техники безопасности ознакомлен

09.06.2026	Ларионов В.С.	
(дата)	(ФИО обучающегося)	(подпись обучающегося)

Инструктаж по охране труда, технике безопасности, пожарной безопасности, а также правилам внутреннего трудового распорядка проведен ответственным за проведение инструктажей обучающимся от профильной организации

10.06.2026	Осина Е.А.	
(дата)	(ФИО инструктирующего)	(подпись инструктирующего)

С инструкцией по охране труда, технике безопасности, пожарной безопасности, а также правилам внутреннего трудового распорядка в профильной организации ознакомлен

10.06.2026	Ларионов В.С.	
(дата)	(ФИО обучающегося)	(подпись обучающегося)

График выполнения работ

Сроки выполнения (число / месяц)	Наименование работ
09.06.2026	Составление основного содержания и названия глав для отчета
10.06.2026 - 11.06.2026	Составление основного содержания 3 главы отчета и сбор информации по главе
13.06.2026	Составление основного содержания 4 главы отчета и сбор информации по главе
15.06.2026 – 17.06.2026	Оформление 3 главы
18.06.2026 – 20.06.2026	Оформление 4 главы
22.06.2026	Оформление документов для сдачи практики
23.06.2026	Защита / сдача Отчета о результатах практики

Обучающийся _____ Лагунов В.С. 24.06.2026
(подпись) (ФИО) (дата)

Содержание объемов выполненных работ подтверждаю:

Руководитель практики от профильной организации _____ _____ 24.06.2026
(подпись) (ФИО) (дата)

м.п.

ХАРАКТЕРИСТИКА

Обучающегося _____Ларионова Владимира Сергеевича _____
(ФИО)

Направление подготовки/специальность 10.05.01 Компьютерная безопасность «Безопасность компьютерных систем и сетей (связь, информационные и коммуникационные технологии)»
Курс ___2____
Форма обучения _____очная _____
(очная, заочная, очно-заочная)

Вид практики Учебно-лабораторный практикум
Место прохождения практики Специализированная лаборатория сетей и систем передачи данных (317 / УЛК №5)
Сроки прохождения практики _____ с 09.06.2026 по 24.06.2026_____

За время прохождения учебной практики Ларионов В. С. зарекомендовал себя как ответственный и исполнительный студент, серьёзно относящийся к порученной работе. Он своевременно выполнял задания и строго придерживался установленных требований. На протяжении всего периода практики студент стремился углубить свои знания и освоить новые практические приёмы работы.

В ходе практики Ларионов В. С. показал уверенное владение базовыми знаниями в сфере информационной безопасности, продемонстрировал умение изучать и анализировать техническую и учебную литературу.

По итогам практики можно сделать вывод, что уровень теоретической подготовки обучающегося достаточен для решения прикладных задач в области информационной безопасности и сетевых технологий.

Руководитель практики
от профильной организации _____ _____
(подпись) (ФИО)

«24» июня 2026 г.

м.п.

РЕФЕРАТ

Отчет 44 с., 31 источн.

Объектом исследования является информационная безопасность как комплексная область профессиональной деятельности. Предметом исследования является совокупность актуальных направлений информационной безопасности, их ключевые задачи и специфика, а также перспективные технологические тренды их развития.

Цель работы - провести анализ актуальных направлений в информационной безопасности.

В ходе выполнения учебно-лабораторного практикума получены следующие результаты:

1. Проведен анализ актуальных направлений в ИБ;
2. рассмотрены возможные перспективы развития информационной безопасности

СОДЕРЖАНИЕ

ВВЕДЕНИЕ ……3

1. Теоретические основы информационной безопасности. ……..5

1.1. Понятие и цели информационной безопасности, а также виды угроз… ……5

1.2. Принципы обеспечения информационной безопасности ……..8

2. Современные направления информационной безопасности ……..14

2.1 Сетевая безопасность……14

2.2 Безопасность операционных систем……15

2.3 Криптографическая защита информации……16

2.4 Безопасность облачных технологий……16

2.5 Безопасность мобильных устройств……17

3. Актуальные задачи специалистов по информационной безопасности..18

3.1. Мониторинг и анализ инцидентов……..18

3.2. Управление рисками……21

3.3. Реагирование на компьютерные атаки……...22

3.4. Проведение аудита безопасности……25

3.5. Обучение пользователей……..26

4. Перспективы развития информационной безопасности ……29

4.1. Искусственный интеллект в ИБ……..29

4.2. Концепция Zero Trust……...30

4.3. Автоматизация процессов защиты ……32

4.4. Подготовка кадров в сфере ИБ……34

ЗАКЛЮЧЕНИЕ……..38

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ……39

ВВЕДЕНИЕ

Технологии сейчас развиваются очень быстро. Это касается компьютеров, интернета и многих других областей. Мы всё чаще используем разные цифровые устройства в работе, учёбе, медицине, финансах и обычной жизни. Благодаря этому информация в наших устройствах становится очень ценной. Она может быть связана с деньгами, здоровьем, личной жизнью или работой, и её потеря или кража могут иметь серьёзные последствия.

Но вместе с этим появляются и новые угрозы. Злоумышленники постоянно придумывают новые способы украсть данные, повредить их, использовать без разрешения или распространить. Это могут быть вирусы, трояны, хакеры, фишинг, мошенничество и другие виды преступлений. Каждый день в мире происходят тысячи кибератак, и их число растёт. Чтобы защитить себя и свои данные, нужно постоянно улучшать способы защиты и быть на шаг впереди преступников.

Информационная безопасность — это набор мер, которые помогают защитить информацию от разных угроз. Она включает в себя организационные, технические, программные и криптографические способы. Организационные меры — это правила и политики работы с информацией, обучение сотрудников и контроль за их соблюдением. Технические меры — это использование антивирусных программ, межсетевых экранов, систем обнаружения вторжений и других инструментов. Программные меры — это специализированное ПО для защиты данных. Криптографические методы — это шифрование информации, чтобы она была конфиденциальной и целой.

Цель этой работы — изучить современные способы защиты информации, понять, чем занимаются специалисты в этой области, и оценить, как будет развиваться информационная безопасность в будущем.

Для этого нужно решить несколько важных задач:

1. Определить основные понятия и термины, связанные с информационной безопасностью.
2. Рассмотреть современные методы защиты информации, включая

организационные, технические, программные и криптографические подходы.

3. Изучить, чем занимаются специалисты по информационной безопасности, их роль и обязанности.

4. Проанализировать текущие тенденции и направления развития в этой области, а также оценить перспективы на будущее.

Информационная безопасность становится всё более важной в современном мире. В условиях цифровизации и большого количества данных, защита информации становится критически важной задачей. Понимание современных методов защиты, задач специалистов и перспектив развития этой сферы поможет лучше подготовиться к будущим вызовам и обеспечить безопасность своих данных

1 Теоретические основы информационной безопасности

1.1. Понятие и цели информационной безопасности, а также виды угроз

Информационная безопасность - это комплекс средств направленный на обеспечение конфиденциальности, доступности и целостности информации от различного вида угроз [1].

Основу современной концепции информационной безопасности составляет триада CIA:

- Confidentiality (конфиденциальность);
- Integrity (целостность);
- Availability (доступность).

Конфиденциальность - доступ к информации только для тех для кого они предназначены, что применимо к видам данных как пароли, реквизиты и корпоративные данные. Примером являются мессенджеры, где сообщения видят только отправитель и получатель [1].

Целостность - это сохранение данных, чтобы они не искажались и оставались точными без ведома владельца, что позволяет защищать данные от подделки и различной подмены, изменений или повреждения. Примером будут цифровые подписи в приложениях банков для подтверждения данных и защите от изменений [1].

Доступность - гарантирует что данные будут получены своевременно и будут надежные для использования. Примером для доступности применима рассылка от МЧС, потому что информации не должна быть ложная и своевременно дойти до населения определенного региона [2].

Основной целью информационной безопасности является защита информации от не предусмотренного доступа, от искажения, изменения, уничтожения или нарушения доступности, чему также способствует соблюдение трех ключевых принципов триады CIA [3].

За существование и развитие цифровой среды появились различные

виды и примеры угроз, каждая разновидность имеет свои особенности, виды и способов действия по защите информации сохраняя доступность.

Современные угрозы можно разделить на несколько категорий:

1. Внешние угрозы – работа злоумышленников, которые не имеют доступа к внутренним системам организации на которую производится атака, применяющие попытки получить доступ извне, с целью кражи данных, выведения системы из строя, шантажа, финансового мошенничества, или иных преследуемых ими цели [4].
примерами внешних угроз являются виды атак как: Man-in-the-Middle, вредоносное ПО, DDoS атаки и другие.

2. Внутренние угрозы – риски, исходящие внутри организации, и связанные с действиями сотрудников, подрядчиков и других лиц, которые имеют доступ к системе, каким-либо данным или инфраструктуре. Последствиями таких угроз являются утечка информации, финансовой потерей, репутационному ущербу [5].
Виды: преднамеренные, непреднамеренные

3. Технические угрозы – это угрозы, использующие различные уязвимости в программном обеспечении, аппаратном обеспечении или сетевой системе, которые могут нанести ущерб по информационной инфраструктуре. Целью является кража данных, нарушении целостности или доступности информации в инфраструктуре организации [6].

Согласно статистике международных компаний в области кибербезопасности, значительная часть успешных атак связана именно с человеческим фактором.
Лаборатория Касперского оценила влияние по опросу более 1,2 тысячи инженеров в сфере Информационных технологий и получили результаты:

- 77% компаний столкнулись хотя бы с одним киберинцидентом за последний 2 года.
- 26% инцидентов были связаны с умышленным нарушением информационной безопасности [7].

Основными принципами в информационной безопасности являются:

- Комплексность – защита информации по этому принципу строится как общая система, которая охватывает все аспекты деятельности организации и предотвращать все актуальные угрозы [1].
- непрерывность защиты – постоянная защита информации, независимо от времени суток, инфраструктуры организации и других факторов [1].
- минимизация привилегий – подход по управлению доступом, где пользователь, программа, или процесс имеют только необходимые и минимальные права в системе [1].
- многоуровневая защита – концепция по обеспечению защиты информации при которой применяются несколько независимых мер безопасности, также они могут располагаться на разных уровнях инфраструктуры. Этот принцип позволяет в случае прорыва одного уровня злоумышленники быстро не смогут получить доступ к другим уровням [1].
- управление рисками – непрерывный процесс анализа и оценки рисков с целью снижения шансов реализации угроз до нормального уровня основанный на ГОСТ Р ИСО/МЭК 27001 [1].
- своевременное обнаружение инцидентов – постоянный контроль состояния инфраструктуры и выявления подозрительной активности как можно быстрее после несанкционированного доступа [1].

Реализация данных принципов позволяет существенно повысить устойчивость информационных систем к современным угрозам.

1.2 Различные виды атак

1.2.1 Социальная инженерия (Social Engineering)

Социальная инженерия - совокупность методов психологического воздействия на человека с целью получения конфиденциальной информации или выполнения действий, выгодных злоумышленнику. Данный вид атаки воздействует не на устройство, а на пользователя [8]. Для получения информации от человека используют доверчивость, невнимательность, спешку, страх или авторитет для достижения своих целей. От Социальной инженерии сложнее всего защититься, потому что каждый сотрудник может допустить ошибку и любые современные средства защиты могут оказаться бесполезными.

Основные разновидности:

- Фишинг (Phishing) — рассылка поддельных писем от имени известных организаций [8].
- Целевой фишинг (Spear Phishing) — атака на конкретного человека или компанию [8].
- Вишинг (Vishing) — мошенничество с использованием телефонных звонков [8].
- Смишинг (Smishing) — атаки через SMS-сообщения.
- Business Email Compromise (BEC)[8] — компрометация корпоративной электронной почты [8].

1.2.2 Вредоносное программное обеспечение (Malware)

Вредоносное программное обеспечение — это программы, предназначенные для нанесения ущерба компьютерным системам, кражи данных или получения несанкционированного доступа. Последствиями может стать потеря информации или нарушение работы систем [8].

Основные виды вредоносного ПО:

- Вирусы - Программы, способные внедряться в другие файлы и распространяться при их запуске пользователем [8].

- Черви - Самостоятельно распространяются по сети без участия пользователя, используя уязвимости операционных систем [8].
- Трояны - Маскируются под полезное программное обеспечение и после установки выполняют вредоносные действия [8].
- Шпионское ПО (Spyware) - Скрытно собирает информацию о пользователе и передаёт её злоумышленникам [8].
- Кейлоггеры - Записывают нажатия клавиш на клавиатуре для получения логинов, паролей и другой конфиденциальной информации [8].

1.2.3 Атаки на учётные записи

Данный вид атак выглядит как подбор паролей различными способами.

Виды от простых до более продвинутых и более быстрые что может занимать от нескольких миллисекунд, до множества лет [8].

Наиболее распространённые методы:

- Brute Force - Полный перебор возможных комбинаций символов до нахождения правильного пароля.Обычно самый долгий способ, но и самый простой, время взлома зависит от длины пароля и алфавита используемого в пароле [8].
- Dictionary Attack - Использование словарей наиболее популярных паролей и комбинаций. Слегка ускоряет способ подбора, но также медленно и не всегда может помочь, если пользователь использует необычный пароль[8].
- Password Spraying - Попытки входа в большое количество учётных записей с использованием нескольких популярных паролей. также позволяет сократить время, но не всегда может помочь. чем больше учётных записей взламывается тем медленнее происходит подбор из-за ограничений мощности [8].
- Credential Stuffing - Использование ранее украденных логинов и паролей для доступа к другим сервисам. Это достаточно продвинутый способ, для него требуется база данных с паролями, которую в настоящее время тяжело достать, но этот способ очень эффективен и быстр [8].

Для защиты от подобных атак используются сложные длинные пароли, многофакторная аутентификация и ограничение количества попыток входа.

1.2.4 Внутренние угрозы (Insider Threats)

Внутренние угрозы возникают со стороны сотрудников организации, подрядчиков или лиц, имеющих легитимный доступ к информационным ресурсам [5].

Особенностью таких угроз является то, что злоумышленник уже обладает определенными правами доступа и знаниями о внутренней инфраструктуре организации.

Внутренние угрозы разделяются на два типа:

- Преднамеренными - Сотрудник сознательно совершает действия, наносящие ущерб организации [5].
- Непреднамеренными - Ошибки персонала, вызванные недостатком знаний или невнимательностью [5].

Типичные примеры:

- передача конфиденциальных данных третьим лицам.
- использование слабых паролей.
- случайное удаление важной информации.
- подключение зараженных носителей информации.

Во многих организациях именно человеческий фактор является одной из основных причин инцидентов информационной безопасности.

1.2.5 Атаки программ-вымогателей (Ransomware)

Ransomware представляет собой вредоносное ПО, основной целью которого является блокировка доступа к данным пользователя вымогания денег или иных целей [8].

После проникновения в систему программа:

1. Шифрует файлы.
2. Блокирует доступ к информации.
3. Отображает требование о выплате выкупа.

4. иногда устанавливает таймер, до удаления данных или ключей шифрования

Современные программы-вымогатели также могут не только шифровать данные, но и предварительно копировать их для последующего шантажа жертвы публикацией информации в общий доступ.

Известными примерами являются: WannaCry, Petya и LockBit.

1.2.6 DDoS-атаки

DDoS (Distributed Denial of Service) — распределённая атака типа «отказ в обслуживании». Атака производится с множества устройств на один сервис для перегрузки сервера организации. Целью данного способа является вывод из строя сервиса делая его недоступным [8].

Для проведения таких атак используются ботнеты — сети заражённых устройств, управляемые злоумышленником.

Последствия DDoS-атак:

- недоступность веб-сайтов.
- нарушение работы онлайн-сервисов.
- финансовые потери.
- снижение репутации организации.

Крупные интернет-компании регулярно сталкиваются с подобными атаками. Борьба с этим видом атак уже активно ведётся блокировки входа на сервис со стороны ботов и проверки по типу “вы не робот?”

1.2.7 Атаки на веб-приложения

Веб-приложения являются одной из наиболее частых целей злоумышленников, потому что многие приложения имеют уязвимости которыми можно воспользоваться для получения данных, нарушения доступности или иных возможностей [8].

SQL Injection - возникает при недостаточной проверке пользовательского ввода и позволяет злоумышленнику выполнять SQL-запросы к базе данных, что сервис сам предоставляет данные [8].

Последствия:

- чтение конфиденциальных данных.
- изменение информации.
- удаление записей из базы данных.

Cross-Site Scripting (XSS) - XSS позволяет внедрять вредоносный JavaScript-код на веб-страницы.

Последствия:

- кража файлов cookie.
- захват пользовательских сессий.
- перенаправление пользователей на вредоносные сайты.

Cross-Site Request Forgery (CSRF) - Заставляет пользователя выполнить нежелательные действия на сайте, где он уже прошёл аутентификацию [8].

Directory Traversal - Позволяет получить доступ к файлам за пределами разрешенного каталога веб-сервера [8].

Command Injection - Позволяет выполнять системные команды на сервере через уязвимости приложения [8].

1.2.8 Атаки типа «Человек посередине» (Man-in-the-Middle)

При данной атаке злоумышленник располагается между двумя сторонами обмена информацией и получает возможность контролировать передаваемые данные [8].

Основные цели:

- перехват логинов и паролей;
- чтение конфиденциальной информации;
- изменение передаваемых данных.

Наиболее часто подобные атаки проводятся через поддельные точки доступа Wi-Fi или посредством подмены сетевых настроек.

1.2.9 Эксплуатация уязвимостей нулевого дня (Zero-Day)

Уязвимость нулевого дня (Zero-Day Vulnerability) — это ранее неизвестная разработчику ошибка в программном обеспечении, для которой ещё не выпущено исправление безопасности [8].

Атака с использованием такой уязвимости называется Zero-Day Attack.

Основная опасность заключается в том, что средства защиты часто не способны обнаружить подобную угрозу, поскольку сигнатуры и механизмы обнаружения ещё не разработаны.

Последствия могут включать:

- полный захват системы;
- установку вредоносного ПО;
- кражу данных;
- обход средств защиты.

Zero-Day атаки считаются одними из наиболее опасных и дорогостоящих инструментов в арсенале киберпреступников.

2 Современные направления информационной безопасности

2.1 Сетевая безопасность

Сетевая безопасность – комплекс мер и технологий направленных на защиту сетевой инфраструктуры организации от несанкционированного доступа и атак.

Основными средствами сетевой защиты являются:

- межсетевые экраны – это система защиты компьютерных сетей, путём контроля трафика в сети, информация фильтруется и разрешённая пропускается, а неизвестная блокируется [9].
- системы обнаружения вторжений (IDS) – это программное или аппаратное средство предназначенное для мониторинга трафика и активности в системе и сети, с проверкой на подозрительную активность или странное поведение [10].
- системы предотвращения вторжений (IPS) – средство обеспечивающие сетевую безопасность, путем обнаружения и предотвращения атак на ресурсы, отличается от IDS в том, что IPS не только обнаруживает, но и блокирует вредоносные действия в реальном времени[10].
- VPN-технологии(Virtual Private Network — виртуальная частная сеть) – технология, благодаря которой создаётся защищённое соединение между устройством и удаленным сервером через интернет, что позволяет шифровать трафик, скрывать IP-адрес и обеспечивать конфиденциальность информации [11].
- сегментация сети – метод разделения сети на подсети, целью этого метода является повышение безопасности, улучшения производительности и управления трафиком, для каждой подсети можно указывать различные правила [12].

Одной из ключевых задач является предотвращение распространения атак внутри корпоративной сети.

2.2 Безопасность операционных систем

Операционные системы – это основа любой информационной системы. Их взлом может привести к полной потере управления над инфраструктурой.

Основные меры защиты:

- регулярное обновление – обновления операционных систем закрывают уязвимости прошлых версий, убирая возможности взлома злоумышленниками [13].
- управление учетными записями – позволяет контролировать доступ пользователей к ресурсам, ограничивать возможности и права для пользователя и вредоносного ПО [13].
- контроль доступа – распределения доступа для пользователей в системе для ограничения доступа к ненужным для определенных пользователей файлам [13].
- антивирусная защита – комплекс мер по защите информационной системы от различного вредоносного ПО, представляющая собой программное обеспечение, которое проверяет устройство на наличие подозрительной активности или файлов [13] .
- журналирование событий – процесс сбора и анализа информации о действиях внутри информационной среды, для проверки на подозрительную активность [13].

Этот комплекс мер направлен на работу и защиту системных ресурсов от несанкционированного доступа [13].

2.3 Криптографическая защита информации

Криптография обеспечивает защиту данных путем их преобразования в недоступный для посторонних вид.

Основные методы:

- симметричное шифрование - метод шифрования где один ключ используется одновременно и для шифрования и расшифрования[14].
- асимметричное шифрование - метод шифрования где используется разные ключи для шифрования открытый ключ и для расшифровки закрытый ключ [15].
- электронная подпись - информация, которая к другой информации в электронном виде [16].
- хэширование - процесс преобразования данных в фиксированную по длинне строку, которая называется хеш-кодом или хешем [17].

Криптографические методы широко применяются в банковской сфере, электронном документообороте и системах электронной коммерции.

2.4 Безопасность облачных технологий

Облачные вычисления позволяют организациям хранить и обрабатывать данные на удаленных серверах [18].

Основные плюсы:

- наличие современных методов защиты информации
- возможность использовать как резервную копию данных
- высокая доступность сервисов
- регулярные обновления безопасности

Основные минусы:

- зависимость от поставщика услуг
- риск утечки данных
- зависимость от интернета
- зависимость от поставщика услуг

Для защиты используются шифрование, многофакторная аутентификация и контроль доступа.

2.5 Безопасность мобильных устройств

Безопасность мобильных устройств - комплекс мер направленных на защиту мобильного устройства и операционную систему устройства [19].

Виды защиты:

- блокировка экрана
- шифрование данных
- регулярные обновления ПО
- использование антивирусов
- контроль доступа
- двухфакторная аутентификация

Мобильные устройства имеют широкое распространение и также требуют актуальные методы защиты, для защиты как и личной информации, так и для корпоративной информации.

3 Актуальные задачи специалистов по ИБ

3.1 Мониторинг и анализ инцидентов

Эффективное обеспечение информационной безопасности любого предприятия невозможно без качественного мониторинга киберугроз. В достаточно крупных компаниях роль органов мониторинга выполняют – центры мониторинга информационной безопасности (SOC). Security Operation Center (SOC) – структурное подразделение организации, которое отвечает за мониторинг IT-среды компании и реагирование на киберугрозы. С точки зрения технической реализации, SOC анализирует все поступающие из различных источников события безопасности; если система фиксирует подозрительные действия, она автоматически или с участием оператора запускает процессы, направленные на блокировку атаки и минимизацию ущерба [20].

Такими источниками являются:

- Журналы ОС (Операционная система);
- Антивирусное ПО (Программное обеспечение);
- ПО, анализирующее защищенность инфраструктуры;
- Сетевое оборудование.

Главная причина, по которой компании разворачивают SOC, - потребность в надежной защите критически важных информационных ресурсов. Такой центр позволяет сократить потенциальный ущерб благодаря тому, что способен быстро заметить и отреагировать на любые инциденты информационной безопасности - как внешние, так и внутренние.

Процессы SOC — это совокупность организационных и технических процедур, которые охватывают четыре направления:

1. Поддержка инфраструктуры SOC;
2. Мониторинг событий безопасности;
3. Расследование инцидентов;
4. Развитие.

Также стоит отметить специфику работы SOC. Эти центры работают круглосуточно, так как различного рода кибератаки происходят в любое время, а ночью их частота даже выше, чем днем. Однако не менее важная особенность заключается в том, что большинство атак обнаруживаются вовсе не в момент вторжения. Злоумышленник может проникнуть в инфраструктуру, а система безопасности узнает об этом только через несколько недель, а иногда и через несколько месяцев. Почему так происходит? Потому что современные целевые атаки - особенно те, что проводятся профессиональными группировками, - строятся по принципу скрытности. Сначала хакер получает самый минимальный доступ, например, через фишинговое письмо одного сотрудника. Дальше он тихо изучает сеть, собирает учётные данные, постепенно повышает свои привилегии. Вся эта активность может выглядеть как обычная работа пользователей. В результате, даже если в компании установлены средства защиты, они могут не подать тревогу, потому что поведение злоумышленника внешне неотличимо от поведения обычного сотрудника. Круглосуточный мониторинг SOC помогает сократить этот разрыв, но полностью исключить задержку обнаружения нельзя. И чем дольше атакующий остается незамеченным, тем серьезнее становятся последствия: он успевает найти самые ценные данные, закрепиться в системе и подготовить пути к отступлению. Именно поэтому специалисты оценивают не только скорость реагирования, но и время присутствия - то, сколько дней или месяцев злоумышленник провёл внутри сети, прежде чем его обнаружили.

Главный элемент любого центра мониторинга — это SIEM, то есть класс программного обеспечения, которое собирает и анализирует события безопасности. Данная технология получает информацию из разных источников: системных и прикладных журналов, логов операционных систем, рабочих станций, межсетевых экранов, систем обнаружения вторжений (IDS) и сетевого оборудования. Поступившие данные SIEM упорядочивает и очищает от всего, что не относится к безопасности. Эта операция называется

нормализацией. После предварительной обработки программа применяет правила корреляции, чтобы выявить взаимосвязи между отдельными событиями, и уже эти связанные инциденты передаются на анализ специалистам IT-поддержки или ИБ. Благодаря SIEM организация получает целостную картину происходящего в своей сети и может быстро реагировать на кибератаки. Если смотреть на функциональную схему, то информация сначала проходит через последовательно расположенные модули сканирования и фильтрации трафика, и только после этого поступает непосредственно в SIEM-систему.

Помимо SIEM, ключевым компонентом современного SOC является технология EDR (Endpoint Detection and Response). Если SIEM смотрит на сеть в целом, то EDR фокусируется на каждом отдельном устройстве - компьютере, ноутбуке, сервере. Эта технология устанавливается прямо на конечные устройства и непрерывно записывает всё, что на них происходит: какие процессы запускаются, какие файлы создаются или изменяются, какие сетевые соединения устанавливаются, какие изменения вносятся в реестр. Главное преимущество EDR в том, что он видит действия, которые не видны на сетевом уровне. Например, злоумышленник может запустить вредоносный скрипт, который не создает подозрительного сетевого трафика, но при этом шифрует файлы на диске. EDR заметит это по поведению процесса и отправит сигнал в SOC. Кроме того, EDR позволяет аналитику «откатиться» назад во времени и посмотреть, что происходило на устройстве до атаки, чтобы понять, как именно злоумышленник проник в систему. В связке с SIEM, который собирает логи со всего периметра, EDR дает точечную, детальную информацию о каждом зараженном хосте.

Одно из самых распространённых корреляционных правил в SIEM звучит так: «три неудачных входа в учётную запись, за которыми сразу следует один успешный». Как это работает? Система получает из журналов событий Windows или Linux записи с кодами ошибок входа. SIEM считает, сколько раз за короткий промежуток времени (скажем, за 5 минут) произошла

ошибка входа для одной и той же учётной записи с одного и того же IP-адреса. Как только число ошибок достигает трёх, а затем регистрируется успешный вход, система поднимает тревогу. Такая картина очень похожа на атаку подбора пароля (брутфорс): злоумышленник перебирает пароли, находит правильный и заходит в систему. Без корреляции SIEM каждое событие (ошибка или успех) выглядело бы как обычное действие. Но связав их вместе, система выявляет явно злонамеренное поведение. Конечно, бывают ложные срабатывания - например, сам сотрудник забыл пароль, трижды ошибся, потом вспомнил и зашёл. Поэтому аналитик SOC, получив такое оповещение, проверяет дополнительные параметры: время суток, местоположение IP, был ли успешный вход сразу после ошибок или с большой задержкой, и принимает решение [20].

3.2 Управление рисками

Управление рисками кибербезопасности — это подход, при котором компания сознательно выбирает, какие угрозы устранять в первую очередь, понимая, что полностью защититься от всего невозможно [21]. Вместо того чтобы пытаться закрыть все уязвимости, организация сосредотачивается на самых опасных.

Процесс обычно разбивают на четыре шага. Сначала выявляют, какие риски вообще есть - смотрят на инфраструктуру, процессы, внешние угрозы и внутренние слабости. Потом оценивают каждый риск на его вероятность и последствия. Далее решают, что с ним делать - снизить (например, купить защитное решение), принять (если защита дороже ущерба), передать (застраховать) или избежать (отказаться от опасной деятельности). И наконец, регулярно проверяют, работают ли выбранные меры, и при необходимости их корректируют.

Важно понимать, что угрозы бывают разными. Это могут быть целенаправленные атаки хакеров, ошибки собственных сотрудников, отказ оборудования, стихийные бедствия и многое другое. Среди наиболее распространенных киберугроз сегодня выделяют кражу данных, вредоносное

ПО, фишинговые атаки, распределённый отказ в обслуживании (DDoS) и внутренние угрозы. Поэтому систему управления рисками выстраивают так, чтобы она учитывала все эти категории.

Существуют готовые методики и стандарты, например NIST CSF, ISO 27001, ISO 31000 или DoD RMF. Они помогают выстроить процесс оценки рисков и сделать его понятным не только для технических специалистов, но и для бизнес-руководства. Внедрение таких систем дает организациям ряд важных преимуществ: надежную защиту информационных ресурсов, непрерывность бизнес-процессов, снижение финансовых потерь от инцидентов и повышение доверия со стороны клиентов и партнеров. Однако на пути к эффективному управлению рисками стоят и серьёзные препятствия: высокие затраты на современные системы защиты, нехватка квалифицированных кадров, сложность адаптации к быстро меняющимся угрозам, низкая культура информационной безопасности среди сотрудников, а также недостаточно развитая нормативно-правовая база и проблемы интеграции различных систем безопасности. Эти слабые места требуют комплексного подхода и постоянного внимания со стороны руководства [22].

3.3 Реагирование на компьютерные атаки

Когда система мониторинга зафиксировала нечто подозрительное, начинается самое главное - реагирование. Мониторинг отвечает на вопрос «что происходит?», а реагирование - на вопрос «что делать?». Главная задача реагирования - не просто зафиксировать атаку, а локализовать её, устранить причину, вернуть системы в нормальное состояние и извлечь уроки.

В мировой практике наиболее признанной методологией реагирования считается подход, описанный в документе NIST SP 800-61 Rev. 2. Весь процесс разбит на шесть последовательных этапов, и каждый из них важен по-своему [23].

Первый этап - подготовка. Он происходит еще до того, как случилась атака. Компания заранее создаёт команду реагирования, разрабатывает план действий, закупает необходимое оборудование и программное обеспечение,

проводит обучение сотрудников. Готовятся списки контактов, запасные носители для сбора данных, инструменты для форензики. Чем лучше подготовка, тем быстрее и эффективнее будет реакция, когда придет настоящий инцидент.

Второй этап - обнаружение и анализ. Здесь специалисты получают сигнал о возможном инциденте - от SIEM, от антивируса, от сотрудника или из внешних источников. Задача специалистов - подтвердить, что инцидент действительно произошел, определить его масштаб (какие системы затронуты, какие данные скомпрометированы), классифицировать тип атаки и оценить, насколько она критична. Это самый сложный этап, потому что многие атаки маскируются под обычную легитимную активность.

Третий этап - сдерживание. Как только инцидент подтверждён, нужно предотвратить его дальнейшее распространение. Сдерживание бывает краткосрочным (например, отключить заражённый компьютер от сети, заблокировать подозрительный IP-адрес) и долгосрочным (временно перевести уязвимую систему в изолированную подсеть, сменить пароли на всех учетках).

Четвертый этап - искоренение. После того как атака локализована, необходимо полностью удалить ее причину. Это может включать удаление вредоносного ПО, восстановление настроек системы до безопасного состояния, установку пропущенных обновлений, отключение скомпрометированных учетных записей, а иногда и полную переустановку операционной системы на зараженных машинах.

Пятый этап - восстановление. Теперь можно возвращать системы к нормальной работе. Данные восстанавливаются из резервных копий, проверяется их целостность, системы возвращаются в штатный режим. Важно, что восстановление начинается только после полной уверенности, что уязвимость устранена и злоумышленник не сможет проникнуть снова через ту же дыру.

Шестой этап - действия после инцидента. Это часто пропускают, но он, возможно, самый важный. Собирается команда, анализируется вся хронология: что сработало хорошо, что плохо, на каком этапе произошла задержка, какие системы оказались не готовы. Пишется подробный отчет, вносятся изменения в политики безопасности и настройки, обновляются инструкции по реагированию.

Рассмотрим, как эти этапы работают на живом примере. Представьте, что в компании из пятисот компьютеров один из сотрудников бухгалтерии открыл вложение из письма с поддельным счётом. На его компьютере активировался вирус-шифровальщик, который начал шифровать файлы не только локально, но и на доступных сетевых дисках. Через несколько минут коллеги заметили, что не могут открыть общие документы, а администратор увидел в системе мониторинга подозрительную активность.

Если компания заранее подготовилась, то у неё есть план реагирования, назначенная группа и регулярные резервные копии — это сработал этап подготовки. Администратор получает оповещение, быстро проверяет логи, подтверждает активность шифровальщика, определяет источник заражения (компьютер бухгалтера) и масштаб (затронуто около двадцати процентов общих файлов на одном диске) — это обнаружение и анализ. Затем группа реагирования немедленно отключает заражённый компьютер от сети и отключает сетевой диск от всех компьютеров, кроме сервера резервного копирования — это сдерживание. С помощью антивируса и анализатора определяют тип шифровальщика, удаляют вредоносные файлы, проверяют остальные компьютеры, устанавливают пропущенный патч на почтовом шлюзе — это искоренение. Восстанавливают зашифрованные файлы из резервной копии, проверяют их целостность, переустанавливают ОС на компьютере бухгалтера и возвращают всё в сеть — это восстановление. Через неделю собирают разбор полётов: выясняют, что почтовый фильтр пропустил письмо из-за старой версии антиспам-базы, обновляют правила фильтрации, проводят внеочередное обучение сотрудников и обновляют инструкции — это

действия после инцидента. Такой подход позволяет не только отразить нападение, но и сделать систему более устойчивой к будущим атакам.

3.4 Проведение аудита безопасности

Аудит информационной безопасности — это независимая проверка того, насколько реальное положение дел с защитой информации соответствует требованиям законов, внутренним политикам и отраслевым стандартам. Простыми словами, это полноценная «ревизия» всей системы защиты [24]. Такая проверка может быть внутренней, проводимой силами самой организации, или внешней, выполняемой независимыми аккредитованными организациями. Кроме того, аудит бывает документарным, когда проверяют наличие и качество политик и регламентов, и техническим, направленным на анализ корректности настроек средств защиты.

В соответствии с требованиями стандарта ГОСТ Р ИСО/МЭК 27001-2021, любая организация обязана через запланированные интервалы времени проводить внутренние аудиты. Их проводят с целью убедиться, что система менеджмента информационной безопасности соответствует требованиям самого предприятия, действует эффективно и постоянно поддерживается в рабочем состоянии, а ее результаты должны быть задокументированы и доведены до соответствующих руководителей [26].

Для повышения эффективности работы специалистов, ответственных за аудит, существуют специализированные методические руководства. Например, российский стандарт ГОСТ Р ИСО/МЭК 27007-2014 в дополнение к указаниям, содержащимся в ИСО 19011, предоставляет развёрнутое руководство по управлению программой аудита системы менеджмента информационной безопасности, по проведению самих аудитов и по определению компетентности аудиторов. Этот стандарт также применим для организаций, которым необходимо понимать или проводить внутренние или внешние аудиты системы менеджмента информационной безопасности [27].

Аудит, как правило, состоит из трёх основных компонентов. Первый - анализ документации: проверяется, есть ли в компании все необходимые

политики и регламенты, утверждены ли они руководством, ознакомлены ли с ними сотрудники. Второй - техническая проверка: насколько корректно настроены средства защиты информации, такие как межсетевые экраны, антивирусы, системы контроля доступа. Третий компонент - опрос сотрудников: знают ли они требования политик безопасности, как часто меняют пароли, знают ли куда сообщать о подозрительных инцидентах.

Предположим, проводится аудит информационной системы, содержащей персональные данные. В ходе проверки аудитор обнаруживает, что пароли от баз данных хранятся в открытом виде в общем текстовом файле, доступном всем сотрудникам IT-отдела. Согласно Федеральному закону №152-ФЗ, одной из основных обязанностей оператора является обеспечение защиты персональных данных от неправомерного доступа. А само по себе использование и хранение данных должно осуществляться в соответствии с требованиями к материальным носителям [25]. В данном случае такое хранение паролей является критическим нарушением и создает прямую угрозу утечки персональных данных. По итогам аудита составляется акт с рекомендацией настроить политику паролей и внедрить средства шифрования для их хранения.

3.5 Обучение пользователей

Даже самые дорогие и современные системы защиты могут оказаться бесполезными, если сотрудник сам откроет подозрительное вложение или сообщит свой пароль по телефону. Человек остаётся самым слабым звеном в любой системе безопасности, потому что его поведение сложно контролировать техническими средствами, а злоумышленники активно используют социальную инженерию. Основная цель обучения сотрудников - сформировать устойчивые навыки безопасного поведения, превратив персонал из потенциальной угрозы в союзников службы информационной безопасности.

Одним из самых эффективных практических методов обучения являются регулярные фишинг-симуляции. С помощью специальных

платформ, например open-source инструмента GoPhish, сотрудникам отправляют безопасные поддельные письма, имитирующие реальные фишинговые атаки. Система фиксирует, кто открыл письмо, перешёл по ссылке или даже ввёл свои учетные данные на подставной странице. Главное преимущество такого подхода - мгновенная обратная связь: если сотрудник ошибся, он сразу получает короткий обучающий модуль, который объясняет, как распознать подозрительное письмо и почему не стоило переходить по ссылке.

Помимо GoPhish, существуют и другие коммерческие и бесплатные платформы, которые позволяют проводить симуляции не только через электронную почту, но и через SMS, мессенджеры, а также имитировать телефонный фишинг. Современные решения также используют генеративный искусственный интеллект для создания максимально реалистичных и персонализированных сценариев атак.

В России требования к обучению сотрудников в области информационной безопасности закреплены на законодательном уровне. В частности, Приказ ФСТЭК России № 17 обязывает организации, обрабатывающие персональные данные или работающие с гостайной, проводить систематическое обучение персонала. Для финансового сектора действует профессиональный стандарт «Специалист по информационной безопасности в кредитно-финансовой сфере», утвержденный Банком России, который содержит рекомендации по квалификационным характеристикам и необходимому объему знаний [28].

Таким образом, обучение пользователей — это не разовое мероприятие, а непрерывный процесс, который сочетает в себе теоретическую подготовку (инструктажи, памятки, видео) и регулярные практические проверки (фишинг-симуляции). Только такой комплексный подход позволяет реально снизить риски, связанные с человеческим фактором, и сделать сотрудников активными участниками системы защиты информации.

4 Перспективы развития информационной безопасности

4.1 Искусственный интеллект в ИБ

Количество кибератак растёт с каждым годом, а число квалифицированных аналитиков, способных их обрабатывать, увеличивается не так быстро. Этот разрыв заставляет компании всё активнее внедрять технологии искусственного интеллекта и машинного обучения в свои системы защиты. ИИ оказывается особенно эффективным там, где традиционные подходы, основанные на сигнатурах и жёстких правилах, дают сбой: при выявлении аномалий, поведенческом анализе и автоматизации рутинных операций. По мнению исследователей, именно искусственный интеллект может выступать в качестве передовой технологии, которая позволяет обнаруживать атаки и решать их быстрее, чем это делают специалисты по кибербезопасности вручную [29].

Одно из самых перспективных применений ИИ — это обнаружение так называемого «бокового перемещения». После того как злоумышленник проник в сеть, например, через фишинговое письмо, он начинает двигаться внутри инфраструктуры, чтобы, например, найти наиболее ценные данные. Визуально это выглядит как череда необычных соединений между хостами, которые человек или обычная SIEM-система могут просто не заметить, особенно в крупной сети с миллионами событий. Именно здесь ИИ показывает свою силу. Современные решения моделируют сеть в виде графа, где узлы — это компьютеры, а ребра — это соединения между ними, и ищут подозрительные паттерны перемещений.

Второе важное направление — это автоматизация реагирования на инциденты с помощью ИИ, которую часто называют SOAR (Security Orchestration, Automation and Response). ИИ здесь берёт на себя первый этап обработки событий: анализирует входящий алерт, обогащает его контекстной информацией и принимает решение, что делать дальше. Если ИИ сталкивается со сложным кейсом, который не может разрешить сам, он подготавливает для человека-аналитика развёрнутое резюме. Такой подход ускоряет реагирование

с часов до минут и снижает количество ошибок из-за человеческого фактора. В статье Афанасьевой также отмечается, что ИИ в сочетании с машинным обучением эффективен при анализе микро-поведения вредоносных программ и любых злонамеренных действий, что помогает принимать более точные решения [29].

Практические примеры уже существуют. Компания Solar представила SIEM-решение со встроенным ИИ-ассистентом, который способен анализировать события на уровне аналитика первой линии. По данным разработчиков, внедрение интеллектуального помощника позволяет сократить до 90% трудозатрат на детектирование инцидентов и реагирование. BI.ZONE, в свою очередь, внедрила AI-ассистента Cubi в свои продукты EDR и SOAR. Cubi помогает формировать сложные поисковые запросы на естественном языке и предоставляет саммари с рекомендациями по каждому алерту. Российская компания Security Vision также сообщила о выходе обновления своей SOAR-платформы с ИИ-ассистентом в формате чат-бота, обученным на лучших мировых практиках реагирования. A Step Logic представила AI Soar, который не просто выполняет сценарии, а формирует их в реальном времени с учётом текущей ситуации.

4.2 Концепция Zero Trust

Классическая модель безопасности, которую долгие годы использовало большинство компаний, строилась по принципу «толстый периметр, тонкое нутро». Считалось, что если злоумышленник не проник через межсетевой экран, то внутри сети можно доверять всем. Эта модель часто называется «Замок и ров»: все ресурсы компании находятся за крепкой стеной, а внутреннее пространство считается безопасным по умолчанию. Однако в мире, где сотрудники работают из дома, из кафе, с личных устройств и используют облачные сервисы, границы компании размылись, и старая модель перестала работать. Ей на смену приходит Zero Trust. Это концепция, которая ломает старую парадигму и провозглашает принцип: «никому не доверяй, всегда проверяй», даже если запрос пришел изнутри корпоративной сети.

Базовым документом по Zero Trust считается публикация Национального института стандартов и технологий США NIST SP 800-207 [30]. В этом документе описаны ключевые принципы, на которых строится Zero Trust-архитектура. Первый принцип: все источники данных и вычислительные службы рассматриваются как ресурсы, которые требуют защиты, независимо от того, находятся они внутри сети или снаружи. Второй: вся коммуникация должна быть защищена и аутентифицирована вне зависимости от сетевого расположения - сетевой адрес больше не определяет уровень доверия. Третий: доступ к ресурсам предоставляется на каждую отдельную сессию, а не на постоянной основе. Четвёртый: решение о доступе принимается динамической политикой, учитывающей множество факторов - кто запрашивает доступ, с какого устройства, откуда и когда, каковы текущие риски. Пятый: аутентификация и авторизация строго выполняются перед предоставлением доступа. Шестой: корпорация непрерывно отслеживает целостность и безопасность всех своих активов. Седьмой: логирование и постоянная переоценка состояния критически важны для поддержания доверия [30].

Чтобы лучше понять эту концепцию, можно привести простую метафору. Старая модель безопасности похожа на стационарный телефон в офисе: если звонок поступил с внутренней линии, то считается, что ему можно доверять, потому что это «своя» линия. Zero Trust работает по правилам публичной сотовой связи: каждый звонок, каждый запрос проверяется заново, независимо от того, откуда он поступил.

Одним из самых ярких примеров внедрения Zero Trust в мире является Google с её инициативой BeyondCorp. Она началась ещё в 2011 году как внутренний проект, позволяющий сотрудникам работать из ненадежных сетей без использования традиционного VPN. BeyondCorp основан на принципе, что доступ к сервисам определяется не сетью, из которой осуществляется подключение, а контекстными факторами - данными о пользователе и его устройстве, и любой доступ должен быть аутентифицирован и авторизован.

Сегодня BeyondCorp используется большинством сотрудников Google для доступа к корпоративным ресурсам.

4.3 Автоматизация процессов защиты

Квалифицированных специалистов по информационной безопасности катастрофически не хватает, а количество атак и объём событий, требующих анализа, растут экспоненциально. При этом время реакции на инцидент должно измеряться минутами, а иногда и секундами, ведь промедление может стоить компании миллионов рублей украденных данных или остановленного производства. Единственный выход из этой ситуации — это автоматическая оркестрация процессов защиты, то есть передача рутинных, повторяющихся задач программам, которые работают быстрее человека, без ошибок и круглосуточно.

Ключевыми технологиями здесь являются SOAR (Security Orchestration, Automation and Response) и BAS (Breach and Attack Simulation). SOAR отвечает за автоматизацию реагирования. Он получает оповещение от SIEM или другого источника, запускает заранее прописанные сценарии (плейбуки) и выполняет необходимые действия без участия человека. BAS, в свою очередь, автоматически проверяет защищенность системы, имитируя действия реального злоумышленника. Эти две технологии отлично дополняют друг друга. Представьте себе типичный сценарий: BAS запускает симуляцию атаки, например, пытается распространить по сети безвредный «имитатор» вируса-шифровальщика. Система обнаружения фиксирует эту активность и отправляет алерт в SOAR. SOAR по заранее настроенному плейбуку автоматически изолирует заражённый хост от сети, отключает учётную запись, с которой проводилась симуляция, и запускает антивирусную проверку. Всё это происходит за секунды, без участия дежурного аналитика. Администратору остаётся только просмотреть отчёт и убедиться, что автоматизация сработала корректно.

Другой, более бытовой пример автоматизации - интеграция кадровой системы (HR) с Active Directory и другими корпоративными сервисами. Когда

сотрудник увольняется, HR вносит запись в 1С или другую учётную систему. Автоматический скрипт (или специальный коннектор) срабатывает: отключает учётную запись в Active Directory, закрывает доступ к корпоративной почте, отзывает права в ERP-системе, отключает доступ к облачным сервисам, а также деактивирует VPN-доступ. Всё это занимает минуты и не требует, чтобы администратор вручную обходил десяток разных систем.

На рынке существует множество решений SOAR как зарубежных, так и российских. Например, Security Vision SOAR — это российская платформа, которая позволяет создавать плейбуки реагирования в визуальном редакторе, интегрироваться с различными средствами защиты (межсетевыми экранами, антивирусами, SIEM) и автоматизировать сотни типовых сценариев. Другой пример — Wazuh, популярная open-source платформа SIEM с элементами SOAR. Она позволяет не только собирать логи и коррелировать события, но и выполнять автоматические действия при обнаружении инцидента: например, запускать скрипты на агенте, блокировать IP через брандмауэр или отправлять уведомления в мессенджеры. Для небольших компаний, у которых нет бюджета на коммерческие продукты, Wazuh может стать хорошей стартовой точкой для внедрения автоматизации.

Автоматизация не ограничивается реагированием на инциденты. Она охватывает также управление уязвимостями (автоматическое сканирование и создание задач на устранение), управление доступом (автоматическое создание учёток при приёме на работу), управление патчами (автоматическая установка обновлений на серверы и рабочие станции) и даже автоматическое тестирование безопасности (BAS как раз про это). В идеале система должна сама обнаруживать уязвимость, формировать задание на исправление, отслеживать его выполнение и перепроверять, закрыта ли уязвимость.

Однако у автоматизации есть и свои риски. Самая большая опасность — это ошибочная блокировка легитимных действий. Например, агрессивный плейбук может принять за атаку обновление операционной системы и

отключить критический сервер в рабочее время. Поэтому к созданию правил автоматизации нужно подходить осторожно. Также важно оставлять за человеком возможность отменить автоматическое действие или принять окончательное решение по сложным, нестандартным инцидентам.

Будущее автоматизации — это самовосстанавливающиеся системы. Это означает, что, если сервер был скомпрометирован, система сама обнаружит атаку, изолирует заражённую часть, переустановит операционную систему из доверенного образа, восстановит данные из резервной копии и вернёт сервер в строй. Полностью самостоятельно и без участия человека. Такие сценарии уже реализуются в некоторых облачных платформах и крупных корпоративных инфраструктурах, но для массового внедрения потребуется ещё несколько лет. В любом случае, автоматизация процессов защиты — это объективная необходимость в условиях, когда людей на все инциденты не хватает, а скорость реакции становится критическим фактором.

4.4 Подготовка кадров в сфере защиты

Ситуация с кадрами в информационной безопасности остается одной из самых острых на российском рынке труда. Спрос на специалистов растет, а предложение отстает. Парадокс в том, что даже при таком дефиците найти подходящего кандидата непросто. Работодатели ищут не просто людей с дипломом, а специалистов с реальными практическими навыками, которые умеют работать с современными инструментами и быстро адаптироваться к меняющимся угрозам. Однако, как отмечается в исследовании Епифанцева, помимо профессиональных знаний и умений, критическое значение имеет и «нравственное здоровье» специалиста - его порядочность, надежность, невозможность подкупа, самообладание и патриотизм. Сочетание высокого профессионализма с низким уровнем моральных качеств представляет серьезную опасность для общества, поэтому вузы, готовящие кадры в сфере ИБ, должны уделять особое внимание воспитательной работе, а работодателям полезно иметь технологии оценки этих качеств при приеме на работу [31].

Одним из самых эффективных форматов практической подготовки

стали киберполигоны - виртуальные среды, где можно законно отрабатывать атаки и защиту в условиях, максимально приближенных к реальным. На киберполигоне разворачивают полноценную инфраструктуру предприятия: серверы, рабочие станции, сетевое оборудование, средства защиты. Участники тренируются обнаруживать угрозы, расследовать инциденты, отражать кибератаки - и всё это в безопасной среде, где ошибка не приведет к реальным последствиям. Киберполигоны используются и в вузовском образовании, и в корпоративном обучении, и на соревнованиях.

Тесно связаны с киберполигонами CTF-соревнования (Capture the Flag) - командные состязания по поиску и эксплуатации уязвимостей. Участники решают задачи из разных категорий: криптография, обратная разработка, веб-безопасность, форензика, эксплуатация сетевых сервисов. За каждую решенную задачу команда получает «флаг» - строку символов, которую нужно найти или вычислить. CTF бывают разного уровня: от студенческих турниров до международных чемпионатов с участием ведущих экспертов. Такие соревнования позволяют не только прокачать навыки в игровой форме, но и зарекомендовать себя перед потенциальными работодателями. В России регулярно проводятся CTF-турниры (например, RedShift CTF), а также запущены государственные программы, такие как «Кибербезопасность в финансах» и молодежные проекты, которые включают подготовку на полигоне, участие в CTF-турнирах и реальные расследования инцидентов. Эти проекты помогают студентам развить технические, аналитические и коммуникативные навыки, а также познакомиться с экспертами ведущих технологических компаний.

Помимо практических соревнований, важную роль играют профессиональные сертификации. Они подтверждают квалификацию специалиста в глазах работодателя, особенно на начальном этапе карьеры, когда опыта работы ещё мало. Среди международных сертификаций наиболее известны OSCP (Offensive Security Certified Professional) - практический экзамен по пентесту, где нужно взломать несколько виртуальных машин за 24

часа, а также CISSP (Certified Information Systems Security Professional) - сертификация для руководителей и архитекторов, подтверждающая знание широкого спектра тем в области ИБ. В России также популярны сертификации от Учебного центра «Информзащита», Академии Positive Technologies и BI.ZONE Academy - стоимость обучения по таким программам варьируется от 30 000 до 300 000 рублей. Однако после 2022 года доступ для российских специалистов к получению международных сертификатов значительно затруднился: экзаменационные центры закрылись, оплата из России не проходит. В ответ на это появились российские аналоги - например, сертификация ССК (Сертифицированный специалист по кибербезопасности), разработанная как замена CISSP и CISM. Были организованы подготовительные курсы и экзамены, и теперь специалисты могут подтверждать свою квалификацию, не уезжая за границу.

Государственные требования к обучению персонала в области ИБ закреплены законодательно. В соответствии с пунктом 18.6 Приказа ФСТЭК России № 17, организации обязаны проводить систематическое обучение персонала по направлению «Информационная безопасность». Хотя сам Приказ № 17 действует уже много лет, стоит учитывать, что с 1 марта 2026 года вступает в силу новый Приказ ФСТЭК № 117, который должен заменить не только его, но и несколько других устаревших документов, регулирующих защиту информации. Однако, как подчёркивает Епифанцев, одного лишь наличия нормативных актов недостаточно. Существует серьезный пробел в части контроля за выполнением требований к материально-техническому обеспечению учебного процесса: не всегда проверяется, действительно ли вузы располагают специализированными классами, сертифицированным оборудованием и программным обеспечением, что неизбежно сказывается на качестве подготовки выпускников. На стадии трудоустройства автор рекомендует дополнительно проводить тестирование соискателей на соответствие профилограмме «Морального облика специалиста по защите информации», а результаты направлять в Рособрнадзор для формирования

обратной связи с вузами [31].

Таким образом, дефицит кадров — это серьёзная проблема, но она же открывает возможности для тех, кто готов учиться. Современные каналы подготовки - киберполигоны, CTF, практико-ориентированные курсы и профессиональные сертификации - позволяют войти в профессию даже без профильного образования, если есть желание и способности.

ЗАКЛЮЧЕНИЕ

Информационная безопасность очень важна в современном мире. Сейчас технологии развиваются быстро, и кибератак становится все больше. Поэтому нужно хорошо защищать данные. С каждым годом число кибератак, краж информации и других угроз растет. Это значит, что методы защиты должны становиться лучше, а специалисты — более подготовленными.

Мы изучили основные направления информационной безопасности. Поняли, какие задачи они решают, чем отличаются и как будут развиваться дальше. Самые важные направления — это искусственный интеллект (ИИ), облако, защита интернета вещей (IoT) и квантовая криптография. Эти технологии помогают лучше защищать информацию и требуют особого внимания.

ИИ помогает в информационной безопасности. Он может автоматически анализировать угрозы, находить подозрительные действия и быстро реагировать на проблемы. Облачные технологии позволяют удобно хранить и обрабатывать данные, но для этого нужно надежно их защищать. Защита интернета вещей тоже важна, потому что сейчас к сети подключается все больше устройств. Квантовая криптография использует особые свойства света и обещает очень высокую безопасность.

Поэтому развитие информационной безопасности — это очень важно для работы современных систем и общества. Чтобы противостоять киберугрозам, нужно не только улучшать старые методы защиты, но и использовать новые технологии. Это искусственный интеллект, облака, защита интернета вещей и квантовая криптография. Только если специалисты будут постоянно учиться и обновлять свои знания, они смогут эффективно защищать информацию.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. Островерхов Б. Что такое информационная безопасность и для чего она нужна. – Текст : электронный // Skillbox Media : [сайт]. – URL: https://skillbox.ru/media/code/informacionnaya-bezopasnost/ (дата обращения: 09.06.2026).
2. Доступность информационных систем: актуальные сведения о факторах и мерах защиты. – Текст : электронный // Сбербанк : [сайт]. – URL: https://www.sberbank.ru/ru/person/kibrary/vocabulary/dostupnost (дата обращения: 09.06.2026).
3. Что такое ИБ и для чего она нужна? – Текст : электронный // Skyeng : [сайт]. – URL: https://skyeng.ru/it-industry/it/chto-takoye-ib-i-pochemu-eto-vazhno-znat/ (дата обращения: 09.06.2026).
4. Внешние угрозы информационной безопасности: как защитить бизнес. – Текст : электронный // Кросстех Солюшнс Групп : [сайт]. – URL: https://ct-sg.ru/mir-ctsg/blog/vneshnie-ugrozy-informatsionnoy-bezopasnosti-kak-zashchitit-biznes/ (дата обращения: 10.06.2026).
5. Что такое внутренняя угроза? – Текст : электронный // Microsoft Security : [сайт]. – URL: https://www.microsoft.com/ru-ru/security/business/security-101/what-is-insider-threat (дата обращения: 10.06.2026).
6. Демидова М. Что такое угрозы информационной безопасности и как с ними бороться. – Текст : электронный // Skillbox Media : [сайт]. – URL: https://skillbox.ru/media/code/chto-takoe-ugrozy-informacionnoy-bezopasnosti-i-kak-s-nimi-borotsya/ (дата обращения: 11.06.2026).
7. Человеческий фактор в кибербезопасности. – Текст : электронный // ICT Moscow : [сайт]. – URL: https://ict.moscow/analytics/chelovecheskii-faktor-v-kiberbezopasnosti/ (дата обращения: 11.06.2026).

8. Types of Attacks. – Текст : электронный // HowToNetwork : [сайт]. – URL: https://www.howtonetwork.org/comptia-and-security/security/chapter-3-threats-and-vulnerabilities/types-of-attacks/ (дата обращения: 13.06.2026).
9. Что такое брандмауэр или межсетевой экран? – Текст : электронный // Лаборатория Касперского : [сайт]. – URL: https://www.kaspersky.ru/resource-center/definitions/firewall (дата обращения: 14.06.2026).
10. Обнаружение и предотвращение вторжений (IDS/IPS): как это работает? – Текст : электронный // Инфарс : [сайт]. – URL: https://infars.ru/blog/obnaruzhenie-i-predotvrashchenie-vtorzheniy-idsips-kak-eto-rabotaet/ (дата обращения: 14.06.2026).
11. Что такое VPN простыми словами? – Текст : электронный // Лаборатория Касперского : [сайт]. – URL: https://www.kaspersky.ru/resource-center/definitions/what-is-a-vpn (дата обращения: 15.06.2026).
12. What is Network Segmentation? – Текст : электронный // HPE Glossary : [сайт]. – URL: https://www.hpe.com/us/en/what-is/network-segmentation.html (дата обращения: 15.06.2026).
13. Таныгин М.О. Безопасность операционных систем : методические указания. – Текст : электронный // Юго-Западный государственный университет : [сайт]. – URL: https://swsu.ru/sveden/files/kek/MU_SRS_Bezopasnosty_operacionnyx_sistem%282%29.pdf (дата обращения: 16.06.2026).
14. Симметричное шифрование. – Текст : электронный // Энциклопедия «Касперского» : [сайт]. – URL: https://encyclopedia.kaspersky.ru/glossary/symmetric-encryption/ (дата обращения: 16.06.2026).

15. ildarin. Асимметричная криптография для чайников. – Текст : электронный // Habr : [сайт]. – URL: https://habr.com/ru/articles/748226/ (дата обращения: 16.06.2026).
16. Федеральный закон от 06.04.2011 № 63-ФЗ (ред. от 31.07.2025) «Об электронной подписи». – Текст : электронный // КонсультантПлюс : [сайт]. – URL: https://www.consultant.ru/document/cons_doc_LAW_112701/c5051782233acca771e9adb35b47d3fb82c9ff1c/ (дата обращения: 17.06.2026).
17. Что такое хэш и как он работает? – Текст : электронный // Skyeng : [сайт]. – URL: https://skyeng.ru/it-industry/it/chto-takoye-khesh-i-kak-on-rabotayet-prostymi-slovami/ (дата обращения: 17.06.2026).
18. What Is Cloud Security? – Текст : электронный // Oracle : [сайт]. – URL: https://www.oracle.com/europe/security/cloud-security/what-is-cloud-security/ (дата обращения: 20.06.2026).
19. Что такое мобильная безопасность? – Текст : электронный // Лаборатория Касперского : [сайт]. – URL: https://www.kaspersky.ru/resource-center/definitions/what-is-mobile-security (дата обращения: 18.06.2026).
20. ГОСТ Р 59547–2021. Защита информации. Мониторинг информационной безопасности. Общие положения. – Текст : электронный // Электронный фонд правовых и нормативно-технических документов : [сайт]. – URL: https://docs.cntd.ru/document/1200180385 (дата обращения: 20.06.2026).
21. Казарян Каторина Камоевна УПРАВЛЕНИЕ РИСКАМИ КИБЕРБЕЗОПАСНОСТИ // StudNet. 2022. №1. URL: https://cyberleninka.ru/article/n/upravlenie-riskami-kiberbezopasnosti (дата обращения: 20.06.2026).

22. Усманбеков Ш. Д. РИСКИ КИБЕРБЕЗОПАСНОСТИ И МЕХАНИЗМЫ УПРАВЛЕНИЯ // Экономика и социум. 2025. №11-1 (138). URL: https://cyberleninka.ru/article/n/riski-kiberbezopasnosti-i-mehanizmy-upravleniya (дата обращения: 20.06.2026).
23. Cichonski P., Millar T., Grance T., Scarfone K. Computer Security Incident Handling Guide : NIST Special Publication 800-61 Revision 2. — Gaithersburg : National Institute of Standards and Technology, 2012. — 79 p. — URL: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf (дата обращения: 20.06.2026). — DOI: 10.6028/NIST.SP.800-61r2.
24. Ан Владимир Робертович, Табакаева Валерия Александровна, Селифанов Валентин Валерьевич РАЗРАБОТКА МЕТОДИКИ АУДИТА КИБЕРБЕЗОПАСНОСТИ ГОСУДАРСТВЕННЫХ ИНФОРМАЦИОННЫХ СИСТЕМ, ОТНОСЯЩИХСЯ К ЗНАЧИМЫМ ОБЪЕКТАМ КРИТИЧЕСКОЙ ИНФОРМАЦИОННОЙ ИНФРАСТРУКТУРЫ, ФУНКЦИОНИРУЮЩИХ НА БАЗЕ ЦЕНТРОВ ОБРАБОТКИ ДАННЫХ // Интерэкспо Гео-Сибирь. 2020. №1. URL: https://cyberleninka.ru/article/n/razrabotka-metodiki-audita-kiberbezopasnosti-gosudarstvennyh-informatsionnyh-sistem-otnosyaschihsya-k-znachimym-obektam (дата обращения: 20.06.2026).
25. Федеральный закон от 27 июля 2006 г. № 152-ФЗ «О персональных данных» : (с изм. и доп.) : статья 19 «Меры по обеспечению безопасности персональных данных при их обработке». — Текст : электронный // КонсультантПлюс : [сайт]. — URL: https://www.consultant.ru/document/cons_doc_LAW_61801/ca9e5658710519f09ab2fdb8196fcb3eb024a051/ (дата обращения: 20.06.2026).

26. ГОСТ Р ИСО/МЭК 27007-2014. Информационная технология. Методы и средства обеспечения безопасности. Руководство по аудиту систем менеджмента информационной безопасности : национальный стандарт Российской Федерации : утвержден и введен в действие Приказом Федерального агентства по техническому регулированию и метрологии от 27 ноября 2014 г. № 1818-ст : дата введения 2015-06-01. — Текст : электронный // Кодекс : [сайт]. — URL: https://docs.cntd.ru/document/1200181890 (дата обращения: 20.06.2026).
27. ГОСТ Р ИСО/МЭК 27001-2021. Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования : национальный стандарт Российской Федерации : утвержден и введен в действие Приказом Федерального агентства по техническому регулированию и метрологии от 15 октября 2021 г. № 1144-ст : дата введения 2022-01-01. — Текст : электронный // Кодекс : [сайт]. — URL: https://docs.cntd.ru/document/1200112881 (дата обращения: 20.06.2026).
28. Приказ ФСТЭК России от 11 февраля 2013 г. № 17 «Об утверждении Требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах» : (с изм. от 15.02.2017 № 27, от 28.05.2019 № 106). — Текст : электронный // РегулХаб : [сайт]. — URL: https://regulhub.kaspersky.ru/upload/iblock/c16/b05dy85jjp6bqsng49n9ue4be3tlfma0.pdf (дата обращения: 20.06.2026).
29. Афанасьева Дарья Владимировна Применение искусственного интеллекта в обеспечении безопасности данных // Известия ТулГУ. Технические науки. 2020. №2. URL: https://cyberleninka.ru/article/n/primenenie-iskusstvennogo-intellekta-v-obespechenii-bezopasnosti-dannyh (дата обращения: 20.06.2026).

30. Марышев Р. В. АНАЛИЗ РАЗВИТИЯ И ВОЗМОЖНОСТИ ИСПОЛЬЗОВАНИЯ СЕТЕЙ С НУЛЕВЫМ ДОВЕРИЕМ // Вестник науки. 2026. №5 (98). URL: https://cyberleninka.ru/article/n/analiz-razvitiya-i-vozmozhnosti-ispolzovaniya-setey-s-nulevym-doveriem (дата обращения: 20.06.2026).
31. Епифанцев Борис Николаевич Проблемные вопросы системы подготовки и отбора кадров в сфере информационной безопасности // Вестник СибАДИ. 2010. №18. URL: https://cyberleninka.ru/article/n/problemnye-voprosy-sistemy-podgotovki-i-otbora-kadrov-v-sfere-informatsionnoy-bezopasnosti (дата обращения: 20.06.2026).